

Key Points :

↳ Open systems Interconnection.
(OSI).
Architecture.

provides a systematic framework
for defining security
attacks, mechanisms, and services.

Security attacks.

passive
(unauthorized
reading of a message
& traffic analysis).

(Active).
modification &
denial of
service.

Security mechanism.

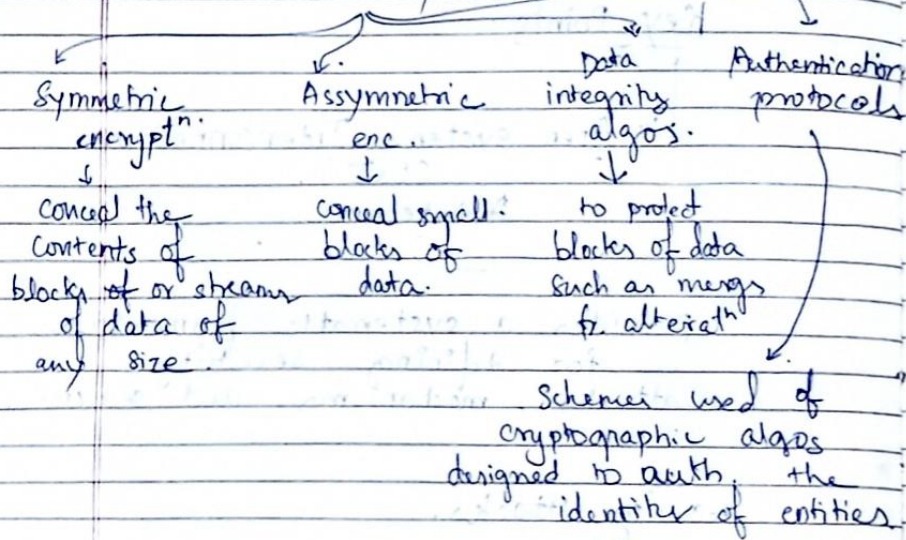
↳ any process to prevent
security attack.

Security services.

↳ Authentication, access control,
data confidentiality & data integrity,
nonrepudiation & availability.

↳ prevention of denial of control
own

Cryptographic Algos & protocols.



(*) Computer Security:

Protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, confidentiality of information system resources.

(*) Confidentiality

Data conf. $\Rightarrow$ private or conf. info is not made available or disclosed to unauthorized individuals.

Privacy: Assumes that individuals control or influence what info related to them can be collected & stored & by whom to whom that info can be disclosed.

Integrity:

- Data Int: Assumes info & programs are changed only in specified & authorized manner.
- System Int: sys performing intended function in an unimpaired manner, free fr. deliberate or inadvertent unauthorized manipulatⁿ of system.

Availability: Assures sys works promptly & service is not denied to authorized users.

(*) OSI Arch.

Threat: potential violatⁿ of security, a possible danger that might exploit a vulnerability.

Attack: Assault on system security that derives from an intelligent threat.

(*) Security Attacks:

passive attack $\rightarrow$ attempts to learn or make use of info fr. the sys.

Active attack → attempts to alter system resources or affect their operatⁿ.

Passive atts:



(i) Release of message contents

(ii). Traffic analysis

figuring out the location & frequency of msgs sent & recieved to obtain useful info.

Passive att is harder to detect due to no alteratⁿ of on system. But encryptⁿ is feasible to prevent it.

⇒ Emphasis is on preventⁿ rather than detection.

Active Attacks:

(i) Masquerade: one entity pretends to be another entity.

(ii) Replay ⇒ passive capture of data unit & its subsequent retransmission to produce unauthorized effect.

(iii) Modificatⁿ of message:

some portion of legitimate msg

is altered, or delayed or reordered, to produce unauthorized effect.

(iv) Denial of service: prevents or inhibits the normal use or management of communications facilities.

Active attack is difficult to prevent but to recover fr. any disruptⁿ or delays caused by them & also detect & trace active attacks.

(*) Security Services:



5 categories.

&
14 specific services.

(*) Authentication:

↳ assuring communication is authentic.

(i) Peer entity authentication:

↳ corroboration of a peer entity & in an association.

(ii) Data origin authentication:

↳ corroboration of the source of data unit.

(*) Model for network security.

↳ principals : The two parties in transactⁿ.

must cooperate for the exchange to take place

A logical information channel is established by the cooperative use of communicatⁿ protocols.

Info access threats : Intercept or modify data on behalf of users who should not have access to that data.

Service threats. Exploit service flaws in computers to inhibit use by legitimate users.

specific:

- (*) Encipherment $\Rightarrow$ use of mathematical algos to transform data into a form that is not readily intelligible.
- (*) Digital Signature $\Rightarrow$ Data appended to, or a cryptographic transformation of, a data unit that allows a recipient of the data unit to prove the source and integrity of the data unit & protect against forgery.
- (*) Access control $\Rightarrow$ enforce access rights to resources.
- (*) Data Integrity.
- (*) Authentication exchange $\Rightarrow$ ensure the identity of an entity by means of info exchange.
- (*) Traffic padding: Insertion of bits into gaps in a data stream to frustrate traffic analysis attempts.
- (*) Routing control: Enables selection of particular physically secure routes for certain data & allows routing changes, especially when a breach is suspected.

- (*) Notarization $\Rightarrow$ Use of trusted 3rd party to assure certain props

Pervasive

- (*) Trusted functionality $\Rightarrow$ Reliable enforcement of security rules.
- (*) Security label $\Rightarrow$ Marking bound to a resource that names or designates security attributes.
- (*) Event Detection.
- (*) security Audit Trail $\Rightarrow$ Maintains logs of sys. activities.
Independent review & examination of sys records & activities.
- (*) Security Recovery.
 $\hookrightarrow$ Restores sys after a security breach
ensures continuity & protection of data.

(*) Access Control:

↳ ability to limit & control the access to host systems & application via communication links.

(*) Data Confidentiality:

↳ protection of data fr. passive attacks.

also protectⁿ of traffic flow from analysis.

"The assurance that data received are exactly as sent by an authorized entity"

Connection-oriented Integrity → protection against both modification & denial of service.

Connection-less Integrity:

→ only against msg modificatⁿ.

There is also distinction b/w service w/ or without recovery.

(*) Non-Repudiation:

↳ Provide protection against denial by one of the entities involved in a communication of having participated in all or part of communication.

(*) Availability service:

↳ availability to be the property of a system or sys resource being accessible & usable upon demand by an authorized sys entity.

(*) Security Mechanisms:

Specific
(Maybe incorporated into the appropriate protocol layer in order to provide some of the OSI Security services).

Pervasive
(Mechanisms that are not specific to any particular OSI Security service or protocol layer).